

Cyber Security Internship Task-1

Internship Program: Cyber Security Internship by Future Interns

Name: Kothamasu Sai Prasad

Task-3: Vulnerability Assessment Report for a Live Website

Task Description

This task focuses on identifying security vulnerabilities in a live website using **read-only and passive analysis techniques**. The objective is to assess the security posture of the application without performing any exploitation.

Objective

The objective of this task is to:

- Analyze a public website for security weaknesses
- Identify common vulnerabilities
- Classify risks based on severity
- Provide clear remediation steps
- Present findings in a professional report

Table of Contents

Section	Topic	Page
1	Introduction	3
2	Tools Used	3
3	Target Details	3
4	Assessment Methodology	4
5	Commands Used	4
6	Assessment Execution	5
7	Evidence Collection	5
8	Findings	6
9	Impact Analysis	12
10	Risk Rating	12
11	Remediation	12
12	Conclusion	13
13	References	13

1. Introduction

Vulnerability assessment is the process of identifying and analyzing security weaknesses in a system without actively exploiting them.

This assessment was performed on **BadSSL**, a platform designed to demonstrate SSL/TLS vulnerabilities in a controlled environment.

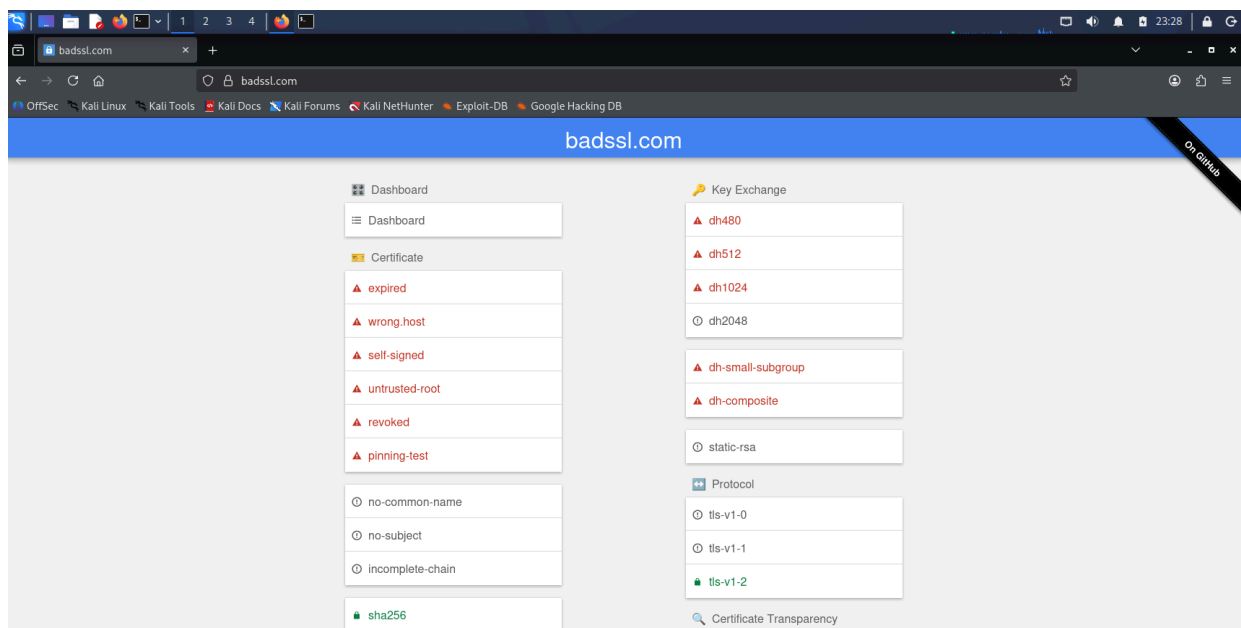
2. Tools Used

- Kali Linux
 - Nmap
 - OWASP ZAP (Passive Scan)
 - Browser Developer Tools (Chrome DevTools)
-

3. Target Details

Target Website:

<https://badssl.com>



Scope:

- Read-only testing only
 - No exploitation performed
 - Passive analysis approach
-

4. Assessment Methodology

The following methodology was followed:

1. Explored the target website and its test endpoints
 2. Analyzed SSL/TLS configurations
 3. Observed browser security warnings
 4. Inspected HTTP headers using DevTools
 5. Performed port and service scan using Nmap
 6. Conducted passive vulnerability scanning using OWASP ZAP
 7. Documented all findings with evidence
-

5. Commands Used

1) Nmap Scan

nmap -sV badssl.com

Purpose:

To identify open ports and running services on the target.

2) OWASP ZAP Scan

Action Performed:

- Entered target URL
- Ran automated passive scan

Purpose:

To detect vulnerabilities without performing attacks.

3) Browser DevTools

Actions Performed:

- Inspected HTTP headers
- Checked console warnings
- Monitored network requests

Purpose:

To identify client-side security issues and misconfigurations.

6. Assessment Execution

The following steps were carried out during the assessment:

- Accessed the target website and explored available endpoints
 - Opened SSL test pages such as:
 - expired.badssl.com
 - self-signed.badssl.com
 - mixed-content.badssl.com
 - Observed browser security warnings
 - Inspected HTTP headers using Developer Tools
 - Identified missing or weak security configurations
 - Performed Nmap scan to identify services
 - Conducted passive scan using OWASP ZAP
 - Collected screenshots as evidence
-

7. Evidence Collection

The following evidence was collected:

- Browser warning screenshots (SSL issues)

- Console warnings (mixed content)
 - HTTP header inspection screenshots
 - Nmap scan results
 - OWASP ZAP alerts
-

8. Findings

Finding 1: Expired SSL Certificate

Type: SSL Misconfiguration

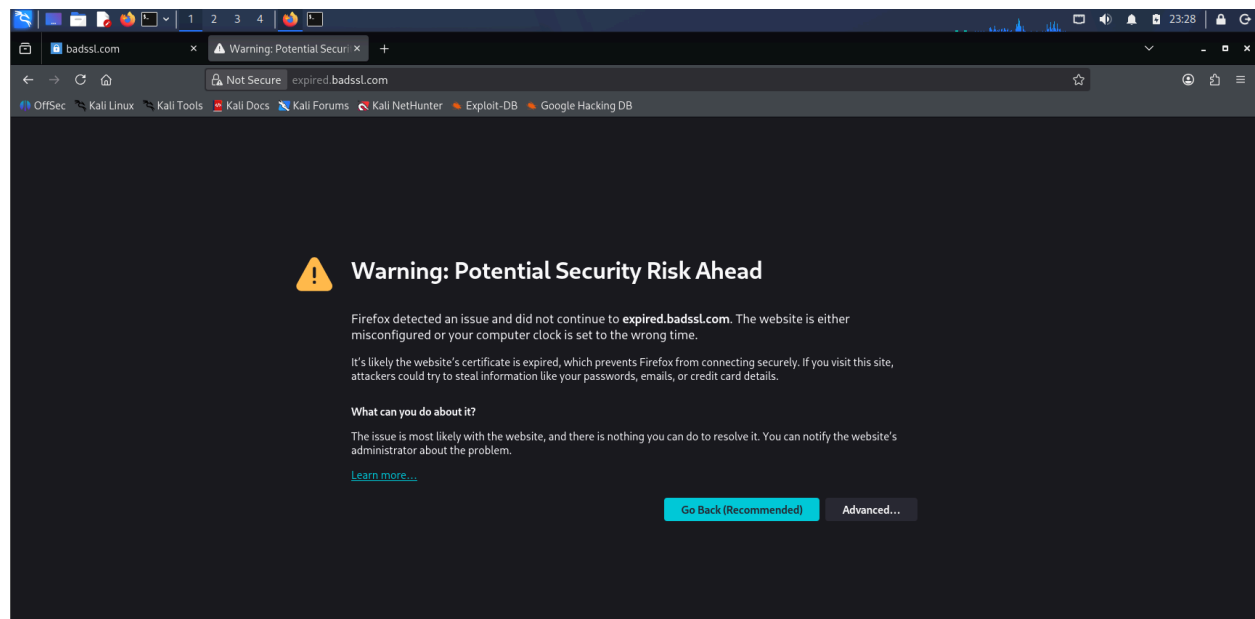
Risk: High

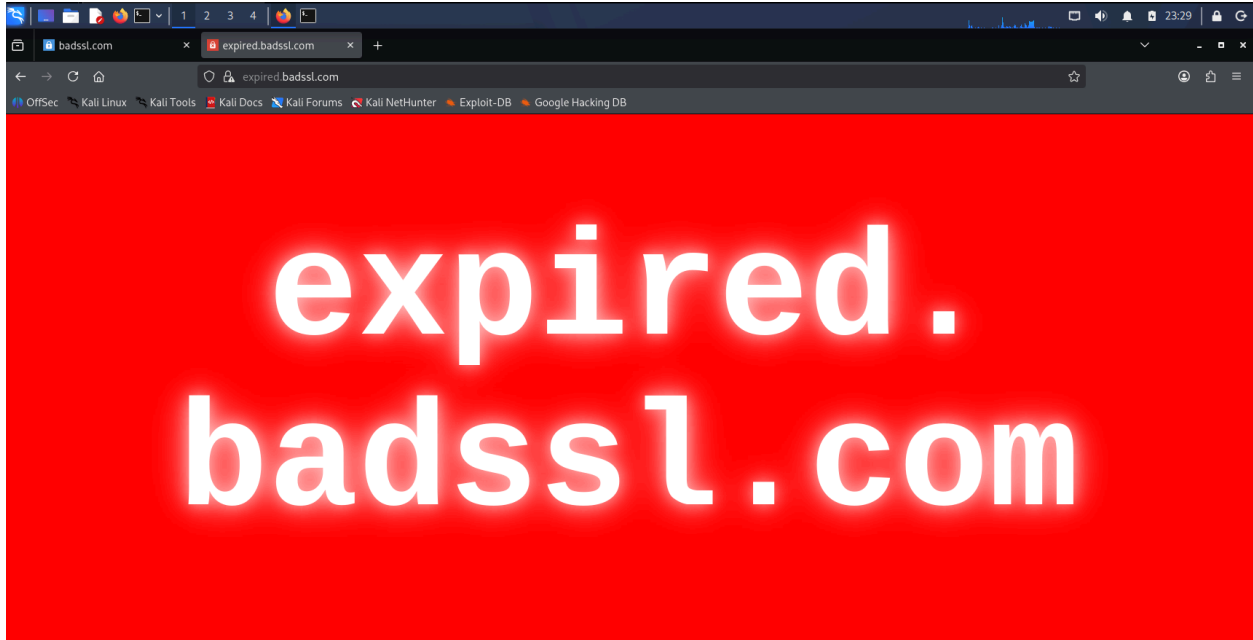
Description:

The application uses an expired SSL certificate.

Evidence:

Browser displays “connection is not private” warning.



**Impact:**

- Loss of user trust
- Risk of man-in-the-middle attacks

Remediation:

- Renew SSL certificates before expiration
 - Enable auto-renewal
-

Finding 2: Self-Signed Certificate

Type: SSL Misconfiguration

Risk: High

Description:

The application uses a self-signed certificate.

Evidence:

Browser shows certificate warning.

**Impact:**

- Not trusted by browsers
- Risk of spoofing

Remediation:

- Use CA-issued certificates
-

Finding 3: Mixed Content

Type: Configuration Issue

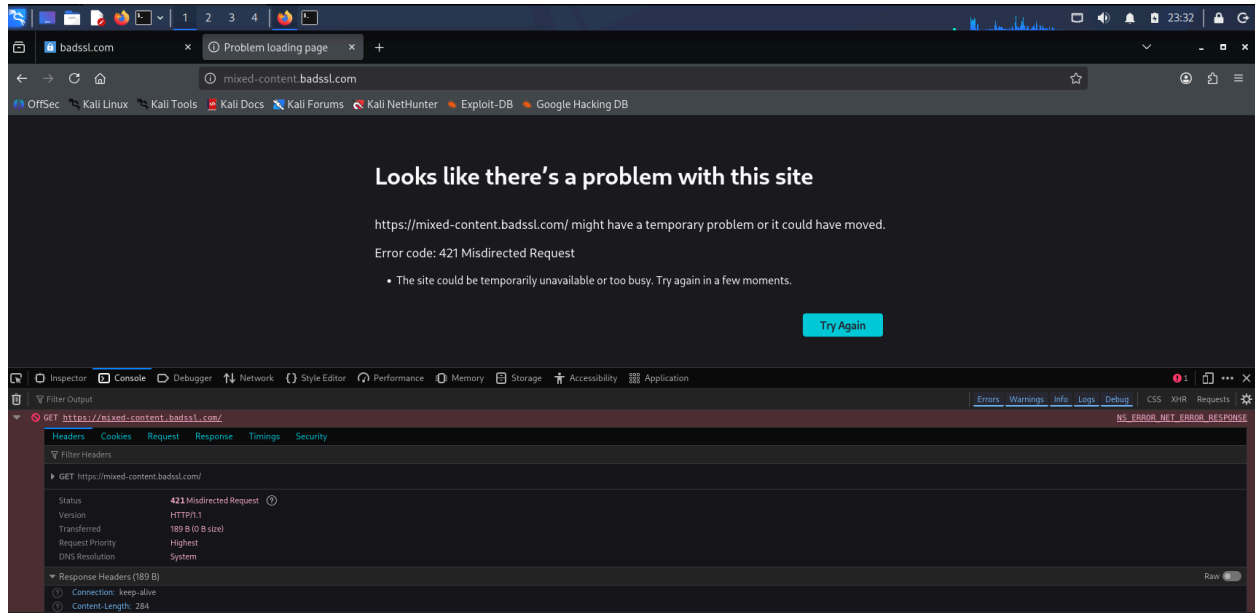
Risk: Medium

Description:

HTTPS pages load HTTP resources.

Evidence:

Warnings in browser console.



Impact:

- Data interception risk
- Breaks secure communication

Remediation:

- Load all resources over HTTPS

Finding 4: Missing Security Headers

Type: Security Misconfiguration

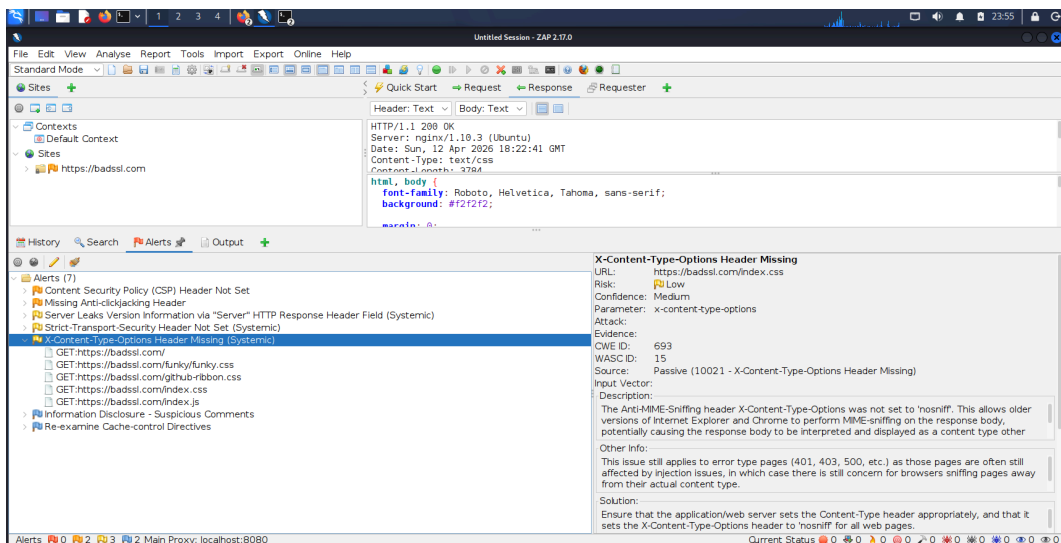
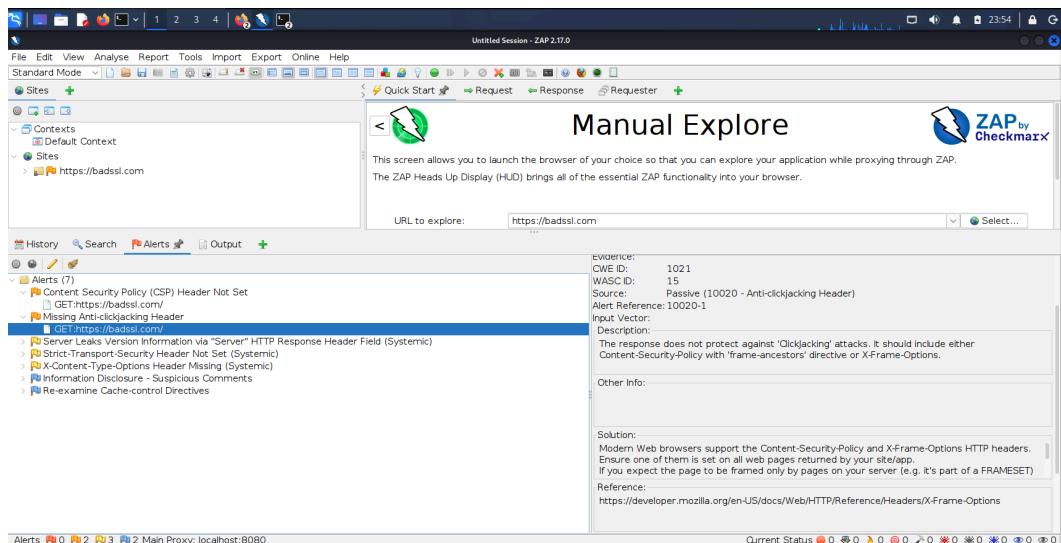
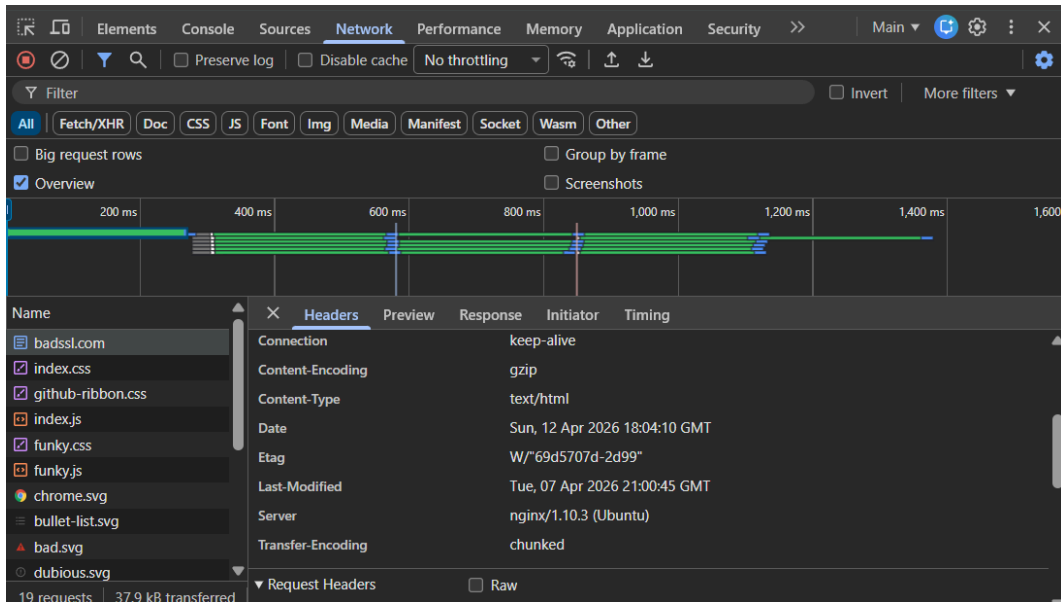
Risk: Medium

Description:

Important security headers are not properly implemented.

Evidence:

Inspection of HTTP response headers using browser Developer Tools showed that important security headers such as Content-Security-Policy, X-Frame-Options, and X-Content-Type-Options are missing or not properly configured.



Impact:

- Vulnerable to XSS and clickjacking

Remediation:

- Implement CSP, HSTS, X-Frame-Options
-

Finding 5: Weak SSL/TLS Configuration

Type: Cryptographic Issue

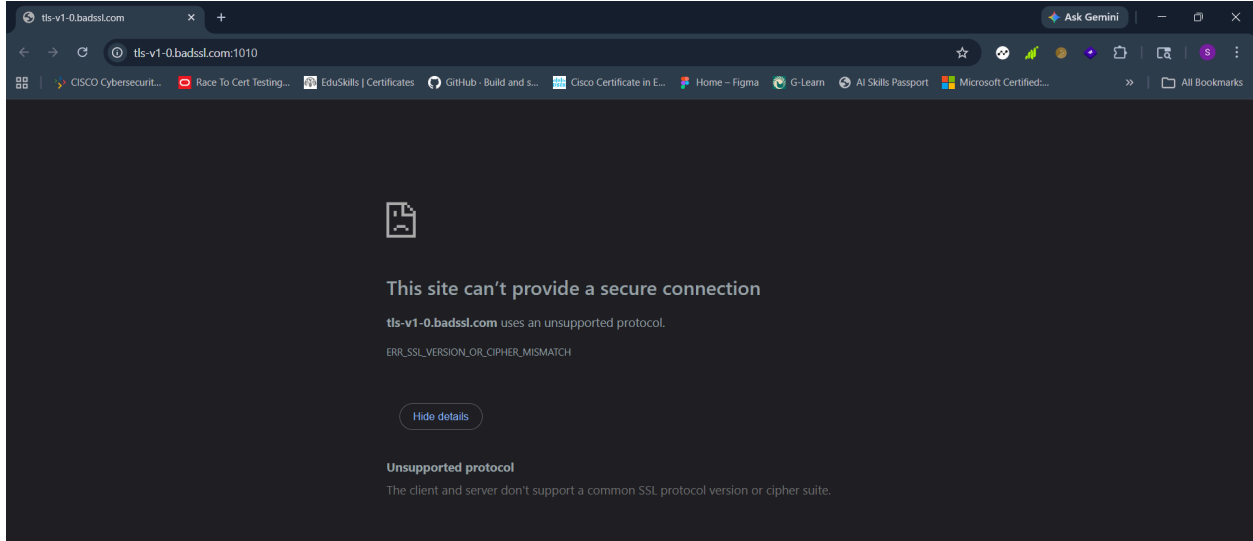
Risk: Medium

Description:

Weak TLS configurations are demonstrated.

Evidence:

Accessing specific endpoints on **BadSSL** (such as TLS 1.0 and TLS 1.1 test pages) triggered browser warnings indicating the use of outdated and insecure SSL/TLS protocols.



Impact:

- Weak encryption risks

Remediation:

- Use TLS 1.2 or higher

- Disable outdated protocols
-

9. Impact Analysis

The identified vulnerabilities may allow attackers to:

- Intercept sensitive information
 - Perform man-in-the-middle attacks
 - Exploit weak encryption
 - Compromise user trust
-

10. Risk Rating

Severity	Description
High	Critical vulnerability
Medium	Moderate risk
Low	Minor issue

11. Remediation

- Use trusted SSL certificates
 - Enforce HTTPS across all pages
 - Implement strong security headers
 - Disable weak SSL/TLS protocols
 - Regularly monitor and update security configurations
-

12. Conclusion

The vulnerability assessment identified multiple **high and medium-risk issues**, primarily related to SSL/TLS configurations and security practices.

Although these vulnerabilities are demonstrated in a controlled environment, they highlight real-world risks that organizations must address.

This task enhanced understanding of security analysis, risk classification, and professional reporting practices.

13. References

- OWASP Top 10
- Nmap Documentation
- OWASP ZAP Documentation
- BadSSL